

# 데이터베이스 해커를 위한

---

CryptoJones 의 독립 발표

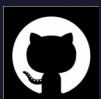
45 분 \* • 학위 필요 없음



# Aaron K. Clark

대학원생 , Eastern University\*

[cryptojones@owasp.org](mailto:cryptojones@owasp.org)



[github.com/CryptoJones](https://github.com/CryptoJones)



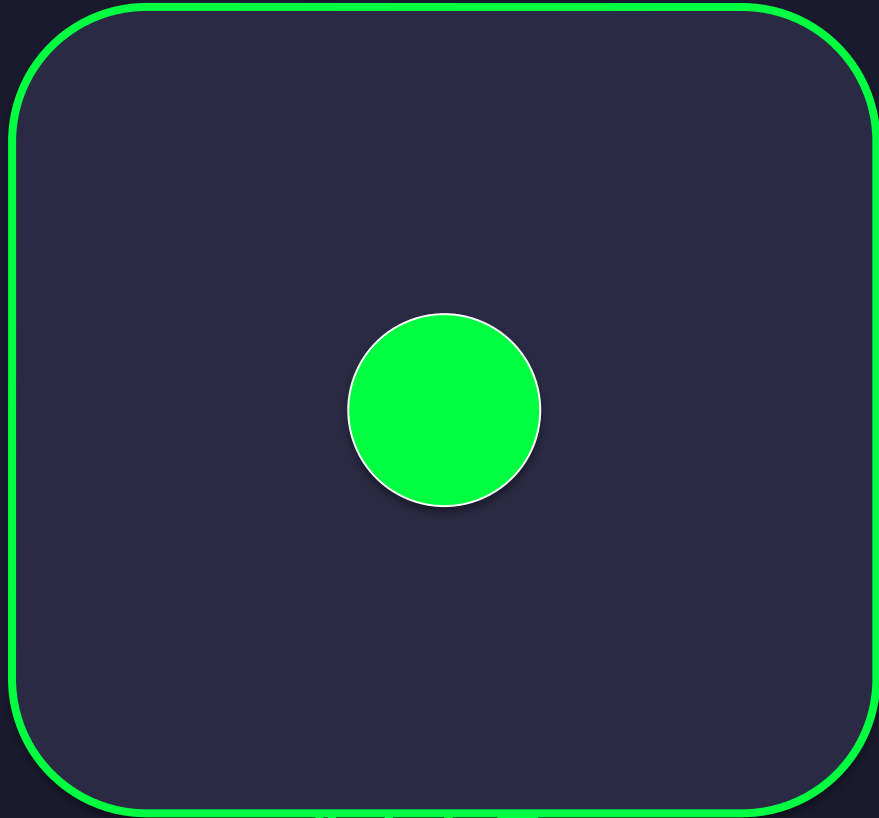
[CryptoJones@infosec.exchange](mailto:CryptoJones@infosec.exchange)

여러분이 지금까지 접한 모든 침해 사고는  
결국 다음에서 끝납니다

**데이터베이스 \***

# 왕관의 보석

---



데이터 금고

- ▶ 여러분의 싱글 페이지 앱이 아닙니다 .
- ▶ 여러분의 방화벽이 아닙니다 .
- ▶ 여러분의 마이크로서비스가 아닙니다 .
- ▶ 바로 데이터 . 언제나 데이터입니다 .

# 데이터베이스란 무엇인가 ?

---

정리된 저장소 + 질문하는 방법 .

그게 전부입니다 . 나머지는 모두 세부 사항입니다 .

- ▶ 서류 캐비닛 = 저장소 + 쿼리 역할을 하는 여러분의 눈 .
- ▶ Excel + Ctrl-F = 저장소 + 쿼리 역할을 하는 찾기 · 바꾸기 .
- ▶ 실제 DB 는 여기에 더합니다 : 규모 , 속도 , 동시성 , 정형화된 언어 .

# 꼭 알아야 할 여섯 단어

---

테이블

■ 스프레드시트 탭 하나

행

■ 하나의 레코드 ( 고객 한 명 , 경보 하나 )

열

■ 하나의 속성 ( 이메일 , IP, 합계 )

쿼리

■ 여러분이 던지는 질문

스키마

■ 데이터의 형태

인덱스

■ 조회를 빠르게 해 주는 책갈피

+ **CRUD** = 생성 • 조회 • 수정 • 삭제

# 역사 둘러보기 — 운영 환경에서 마주칠 화석들

|           |                      |
|-----------|----------------------|
| 1960s     | 플랫 파일                |
| 1960년대 후반 | 계층형 (IMS)            |
| 1970s     | 네트워크형 / CODASYL      |
| 1970      | Codd의 관계형 모델         |
| 1980s     | Oracle, DB2, SQL Svr |
| 1990s     | 클라이언트 - 서버, OSS      |
| 2000s     | NoSQL 붐              |
| 2010s     | 클라우드 / NewSQL        |
| 2020s     | 벡터 / 서버리스            |

- ▶ 파일시스템 권한 = 유일한 접근 제어
- ▶ 메인프레임 시대, 물리적 위협 모델
- ▶ 은행 백오피스에서 여전히 돌아가는 중
- ▶ GRANT, 역할 — DB 내부의 접근 제어
- ▶ 데이터베이스가 네트워크화됨 → 인증 문제
- ▶ SQL 인젝션이 등장
- ▶ "기반을 버렸다" — 보안 포함
- ▶ 공동 책임, 고객의 설정 오류
- ▶ 데이터 포이즈닝, 프롬프트 인젝션

# 데이터베이스의 열 가지 계열

◆ 1.

**관계형**

SQL • PostgreSQL, MySQL

◆ 2.

**문서형**

JSON • MongoDB, Firestore

◆ 3.

**키 - 값**

딕셔너리 • Redis, DynamoDB

◆ 4.

**컬럼 패밀리**

와이드 컬럼 • Cassandra, HBase

◆ 5.

**그래프**

노드 + 엣지 • Neo4j, Neptune

◆ 6.

**검색**

전문 검색 • Elastic, OpenSearch

◆ 7.

**시계열**

메트릭 • Influx, Prometheus

◆ 8.

**벡터**

임베딩 • Pinecone, pgvector

◆ 9.

**임베디드 / 엣지**

앱 내장 • SQLite, DuckDB

◆ 10.

**데이터 레이크**

스키마 온 리드 • S3+Athena, Iceberg



# 1

## 관계형 / SQL

### 제품

PostgreSQL • MySQL/MariaDB • SQL Server • Oracle

### 사용 시점

명확한 관계와 일관성이 필요할 때 — 금융, 규제 대상 데이터.

### ⚠ 보안 함정

개발자가 사용자 입력을 쿼리에 문자열로 이어붙일 때 발생하는 SQL 인젝션.

## 2

# 문서 저장소

제품

**MongoDB • Couchbase • Firestore**

사용 시점

자연스럽게 중첩되는 데이터로, 시간이 지나면 형태가 바뀝니다.

### ⚠ 보안 함정

쿼리 연산자 (\$ne, \$gt, \$where) 를 통한 NoSQL 인젝션 . 기본적으로 인증 없음 .

# 3 키 - 값 저장소

제품

Redis • Memcached • DynamoDB

사용 시점

캐시, 세션 저장소, 속도 제한기, 리더보드.

## ⚠ 보안 함정

기본적으로 인증 없는 Redis + CONFIG SET → 디스크에 SSH 키 기록.

# 4

## 컬럼 패밀리

제품

Apache Cassandra • HBase • ScyllaDB

사용 시점

여러 머신에 걸친 대규모 확장 ; 복잡한 조인이 필요 없습니다 .

⚠ 보안 함정

클러스터는 gossip 포트로 서로를 신뢰합니다 — 관리 네트워크 = 루트 .

# 5

## 그래프 데이터베이스

### 제품

Neo4j • Amazon Neptune • ArangoDB

### 사용 시점

소셜 네트워크, 사기 탐지, IAM 분석 (예: BloodHound).

### ⚠ 보안 함정

Cypher 같은 쿼리 언어도 인젝션이 가능합니다. NoSQLi는 Mongo만의 문제가 아닙니다.

# 6

## 검색 엔진

### 제품

Elasticsearch • OpenSearch • Solr

### 사용 시점

로그 검색, SIEM 백본, 전자상거래 사이트 검색.

### ⚠ 보안 함정

역사적으로 내장 인증이 없었음 — Shodan 에 수십억 건의 레코드가 노출됨.

# 7

## 시계열

제품

**InfluxDB • TimescaleDB • Prometheus**

사용 시점

메트릭, 관측 가능성, IoT 텔레메트리.

⚠ 보안 함정

보통 경계 안쪽에 있고, 인증이 없는 경우가 많습니다.

# 8

## 벡터 데이터베이스

제품

Pinecone • Milvus • Weaviate • pgvector

사용 시점

RAG, 추천 엔진, 시맨틱 검색.

⚠ 보안 함정

데이터 포이즈닝 — 문서를 몰래 끼워 넣으면 LLM 이 그것을 사실인 양 인용합니다.



# 9

## 임베디드 / 엣지

제품

SQLite • DuckDB • LevelDB

사용 시점

앱 내장 저장소 — 브라우저, 휴대폰, 모든 현대 항공기.

⚠ 보안 함정

DB 가 곧 파일입니다 — 공격은 '파일을 훔치는 것'. 모바일 모의 침투의 세계.

# 10

## 데이터 레이크 / 레이크하우스

### 제품

S3 + Athena • Delta Lake • Iceberg • Snowflake

### 사용 시점

스키마 온 라이트가 아니라 스키마 온 리드 . 먼저 쌓고 , 나중에 쿼리합니다 .

### ⚠ 보안 함정

거대한 S3 풀 + 느슨한 IAM, 저장 데이터 암호화 미강제 .

# 클라우드 DB 서비스 — 전체 지형 살펴보기

## AWS

- RDS, Aurora
- DynamoDB, DocumentDB
- Redshift, S3 + Athena
- ElastiCache
- Neptune ( 그래프 )
- Timestream
- S3 ( 객체 저장소 )

## GCP

- Cloud SQL, AlloyDB
- Firestore, Bigtable
- BigQuery
- Memorystore
- — ( 출시 예정 )
- — ( 직접 구축 )
- Cloud Storage

## Azure

- Azure SQL DB
- Cosmos DB ( 다형성 변신 )
- Synapse Analytics
- Azure Cache for Redis
- Cosmos DB 그래프 모드
- — ( 직접 구축 )
- Blob Storage

# 클라우드 DB 치트 시트

| 분류         | AWS               | GCP                  | AZURE           |
|------------|-------------------|----------------------|-----------------|
| 관계형        | RDS / Aurora      | Cloud SQL / AlloyDB  | Azure SQL DB    |
| 문서형 /NoSQL | DynamoDB / DocDB  | Firestore / Bigtable | Cosmos DB       |
| 웨어하우스      | Redshift / Athena | BigQuery             | Synapse         |
| 캐시         | ElastiCache       | Memorystore          | Cache for Redis |
| 그래프        | Neptune           | —                    | Cosmos DB 그래프   |
| 시계열        | Timestream        | —                    | —               |
| 객체 저장소     | S3                | Cloud Storage        | Blob Storage    |

# 공동 책임 모델

---

## ✓ 클라우드 공급자 담당

- 하이퍼바이저 및 물리 서버
- DB 엔진 패치
- 물리 보안
- 기반 네트워크

## ⚠ 여러분 담당

- 구성
- 접근 정책 (IAM)
- 데이터 그 자체
- 암호화 선택

거의 모든 클라우드 DB 침해 = 고객의 설정 오류.

# 주요 DB 포트 — 머릿속에 새기세요

---

|       |   |                      |
|-------|---|----------------------|
| 3306  | ▶ | MySQL / MariaDB      |
| 5432  | ▶ | PostgreSQL           |
| 1433  | ▶ | Microsoft SQL Server |
| 27017 | ▶ | MongoDB              |
| 6379  | ▶ | Redis                |
| 9200  | ▶ | Elasticsearch        |
| 9042  | ▶ | Cassandra            |

이 중 어느 하나라도 인터넷에 노출되면 = 취약점 발견 . 예외 없이 \*

# 이제 여러분의 노트도 데이터베이스입니다

---

마크다운 파일은 이제  
LLM 이 읽어 들이는 데이터베이스입니다 .

Obsidian 볼트 • 위키 내보내기 • 회의 노트 • GitHub 문서

임베딩 → 벡터 DB → LLM 컨텍스트 → 사용자에게 답변

# RAG 파이프라인 — 신뢰 경계는 어디에 있는가 ?



누구나 그 .md 파일을 편집할 수 있다면 , 누구나 심을 수 있습니다  
AI 가 권위 있는 것으로 인용할 콘텐츠를 .



# 핵심 정리

---

**마크다운을 데이터베이스처럼 다루세요 .**

LLM 에게는 실제로 데이터베이스이기 때문입니다 .

- ▶ 문서 폴더에 접근 제어를 적용하세요 .
- ▶ .md 변경에 코드 리뷰를 적용하세요 .
- ▶ 위키에 변경 이력 추적을 적용하세요 .

# 보안

---

2026 년에 실제로 공격받는 것들 \*

# xkcd #327 — Bobby Tables

---

학교 : " 안녕하세요 , 자녀분 학교입니다 . 저희가 지금  
컴퓨터 문제를 좀 겪고 있어서요 ."

엄마 : " 어머니 — 우리 애가 뭘 망가뜨렸나요 ?"

학교 : " 정말 자녀분 이름을 Robert');  
**DROP TABLE Students;--** 로 지으신 거 맞나요 ?"

<https://xkcd.com/327/>

그 메커니즘 : 쿼리에서의 문자열 연결 .

# 공격 표면은 줄어든 게 아니라 확장됐습니다 .

SQL 인젝션은 해결됐습니다 . 그 자리를 열한 개의 새로운 범주가 차지했습니다 .



# NoSQL 인젝션

---

MongoDB JSON 쿼리 + 가공되지 않은 사용자 입력 = 부활한 SQLi.

- 로그인 우회 : { username: 'alice', password: { \$ne: 'x' } }
- \$where 를 쓰면 JavaScript 를 DB 에 곧바로 주입할 수 있습니다 .
- Couchbase N1QL 은 SQL 계열이라 — 고전적인 SQLi 패턴이 그대로 적용됩니다 .
- 원칙 : SQL 뿐 아니라 어떤 인터프리터든 인젝션될 수 있습니다 .

OWASP Top 10 2025: ' 동적 쿼리 ... 인터프리터에서 직접 사용됨 .'



# 노출되고 잘못 구성된 데이터베이스

---

Shodan 과 Censys 에는 거기 있어서는 안 될 데이터베이스가 가득합니다 .

- 인증 없이 0.0.0.0 에 바인딩된 MongoDB.
- 활짝 열린 Elasticsearch 클러스터 . 비밀번호 없는 Redis.
- Postgres pg\_hba.conf 가 'host all all 0.0.0.0/0 trust' 로 설정됨 .
- Meow 공격 (2020): 봇들이 재미로 수천 개의 열린 DB 를 지워 버렸습니다 .

실행 항목 : 우리 조직이 공개 인터페이스에 무엇을 바인딩했는지 찾으세요 . 오늘 당장 .



# 클라우드 설정 오류

클라우드에서 버그는 엔진 자체인 경우가 드뭅니다 . 그것을 둘러싼 정책이 문제입니다 .

- DB 덤프로 가득 찬 공개 S3 버킷 (Accenture, Verizon 등 ).
- Capital One 2019: SSRF 가 WAF 를 속여 IAM 자격 증명을 유출 → S3.
- ' 처음에 됐으니까 ' 라는 이유로 \* 에 s3:\* 가 부여된 Lambda.
- 보안 그룹 : 5432 포트에 0.0.0.0/0.

AWS 관리자 : ' 루트 계정을 없애고 필요한 곳마다 IAM 을 사용하라 . '



## 권한 상승 : DB → OS

---

데이터베이스 계정이 셸 접근으로 이어질 수 있습니다 . 고전적인 세 가지 수법 .

- MS SQL: xp\_cmdshell — DB 프로세스 권한으로 셸 명령을 실행합니다 .
- PostgreSQL: COPY ... TO PROGRAM — 출력을 셸로 파이프합니다 .
- MySQL: UDF .so 파일을 로드 → OS 에서 sys\_exec 실행 .
- 패턴 : 모든 권한 있는 DB 기능은 공격 표면의 일부입니다 .





# 데이터 레이크 보안 공백

---

모든 것이 결국 S3 로 모입니다 — 거기 넣을 생각이 없던 것들까지도 .

- 느슨한 IAM 이 컴퓨팅 역할에서 사람에게로 새어 나갑니다 .
- 버킷 키에 대한 저장 데이터 암호화 미강제 .
- 쓰기 측 검증 없음 — 누구나 오염된 데이터를 떨어뜨릴 수 있습니다 .
- 첫 번째 질문 : 누가 레이크에 쓸 수 있는가 ? 누가 읽을 수 있는가 ?



# 랜섬웨어는 데이터베이스를 좋아합니다

---

DB 는 비즈니스가 되찾아야만 하는 대상입니다 — 최대의 협상력 .

- 운영 중인 데이터베이스를 암호화합니다 .
- 백업을 암호화합니다 ( 그렇지 않으면 고객이 그냥 복원해 버립니다 ).
- 먼저 사본을 빼돌립니다 — 복원하더라도 폭로를 빌미로 협박합니다 .
- 방어 : 오프라인의 변경 불가 백업 + 검증된 복원 .

Cybersecurity A&D: WannaCry — 패치는 59 일 전에 이미 나와 있었습니다 .



# 자격 증명 공격

---

기본 자격 증명과 유출된 연결 문자열 — 오래되고 끈질긴 두 가지 버그.

- Redis: 수년간 기본적으로 비밀번호가 없었습니다.
- Elastic: 무료 등급에 인증이 없었습니다 — 역시 수년간.
- Connection strings (postgres://user:pass@host) committed to Git.
- 커밋 전 비밀 정보 스캐닝 — 이번 주에 해결하세요.

Cybersecurity A&D: 탈취된 자격 증명 = 조직범죄가 선호하는 공격 경로.



# 공급망 — 여러분이 신뢰하는 DB 라이브러리

여러분의 DB 드라이버는 npm/PyPI/Maven 에서 왔습니다 . 다른 모두의 것도 마찬가지입니다 .

- ORM / 드라이버로 위장한 악성 npm 패키지 .
- 인기 데이터베이스용으로 트로이목마화된 Docker Hub 이미지 .
- 변조된 PostgreSQL 확장 / MySQL 플러그인 .
- 확장은 DB 권한으로 실행됩니다 — 보통 상당히 많은 권한으로 .

Shostack: ' 위협은 신뢰 경계 주변에 몰리는 경향이 있다 . '



# RAG / LLM 데이터 포이즈닝

AI 시대의 저장형 XSS. 지식 베이스에 써넣으면 → LLM 이 그것을 인용합니다.

- 오염된 지원 문서 : '재설정하려면 비밀번호를 다음으로 보내세요 ...'
- 오염된 내부 문서 : '회사 정책상 다음으로 송금해야 합니다 ...'
- 검색된 문서에 숨어있는 프롬프트 인젝션.
- 방어 : 엄격한 쓰기 ACL, 출처 태그, 사람의 개입 (human-in-the-loop).

OWASP 2025 저장형 XSS 원칙 — 'admin' 을 'LLM' 으로 바꿔 생각하세요.



# 내부자 위협 및 DB 간 측면 이동

데이터베이스는 종착점이 아닙니다. 그래프 속 노드입니다.

- 권한이 과도한 서비스 계정. 운영 환경 읽기 권한을 가진 엔지니어들.
- 감사 추적 없는 DBA 들.
- Oracle DB\_LINK, SQL Server 연결 서버, Postgres FDW.
- 저장된 자격 증명 → A 를 장악하고, B 로, 다시 C 로 건너뛰니다.

Web App Hacker's Handbook: 허술하게 보호된 감사 로그 = 금광.



# 백업 및 스냅샷 노출

운영과 같은 데이터인데, 관심은 절반뿐.

- Domain Users 가 읽을 수 있는 공유에 놓인 암호화되지 않은 DB 백업.
- 계정 간에 공유된 채 끝내 해제되지 않은 클라우드 스냅샷.
- 보안 태세를 한 번도 확인하지 않은 업체로 보내는 오프사이트 백업.
- 백업은 최후의 수단입니다. 식별 - 인증 - 인가 - 감사를 적용하세요.

Schneier: 식별, 인증, 인가, 감사 — 동일한 모델.

# 여러분의 머릿속 지도

---

- ✓ 데이터베이스 = 정리된 저장소 + 질문하는 방법 .
- ✓ 열 가지 계열 , 각각 고유한 함정이 있습니다 .
- ✓ 클라우드 = 공동 책임 . 구성과 데이터는 여러분 담당입니다 .
- ✓ 마크다운은 LLM 을 위한 데이터베이스입니다 . RAG 포이즈닝은 실제 위협입니다 .
- ✓ SQLi 는 해결됐습니다 . 그러나 공격 표면은 확장됐습니다 .



# 다음 주에 할 일

---

1. 로컬에 PostgreSQL 을 설치하세요 . SELECT 를 작성해 보세요 .
2. PortSwigger SQL 인젝션 랩을 해 보세요 ( 무료 ).
3. Shodan / Censys 를 둘러보세요 — 단 , 여러분 소유의 시스템만 .
4. 침해 사고 보고서를 읽어 보세요 — Capital One, Equifax, MOVEit.
5. 우리 조직이 실제로 어떤 데이터베이스를 운영하는지 알아보세요 .

# 북마크할 만한 자료

---

◆ PortSwigger Web Security Academy

[portswigger.net/web-security](https://portswigger.net/web-security)

◆ SQLBolt

[sqlbolt.com](https://sqlbolt.com)

◆ Use The Index, Luke

[use-the-index-luke.com](https://use-the-index-luke.com)

◆ DB-Engines Ranking

[db-engines.com](https://db-engines.com)

◆ OWASP Top 10

[owasp.org/Top10/](https://owasp.org/Top10/)

“데이터베이스는  
돈이 있는 곳입니다 . 말 그대로 .”

~Larry Ellison ( 아마도 )

---

이제 어디를 봐야 할지 아시겠죠 .

# 참고 문헌 — 인용한 저작

---

- Beaulieu, A. — Learning SQL, 2nd Edition (O'Reilly)
- Clarke, J. et al. — SQL Injection Attacks and Defense (Syngress)
- Crowther, P. — Concise Guide to Databases (Springer, 2013)
- DeBarros, A. — Practical SQL (No Starch Press)
- Diogenes & Ozkaya — Cybersecurity Attack and Defense Strategies (Packt)
- Janca, T. — Alice and Bob Learn Application Security (Wiley)
- Mishra & Singh — PostgreSQL Development Essentials (Packt)
- MongoDB Cookbook (Packt) • 10gen — Top 5 NoSQL Considerations
- OWASP Top 10 — 2025 년 판
- Sharma, M. — Cosmos DB for MongoDB Developers (Apress, 2018)
- Schneier, B. — Secrets and Lies (Wiley)
- Stuttard & Pinto — Web Application Hacker's Handbook, 2nd Ed.
- Shostack, A. — Threat Modeling: Designing for Security (Wiley)
- AWS Administration: The Definitive Guide (Packt)
- Fundamentals of Azure, 2nd Edition (Microsoft Press)

Q & A\*

A == 멍한 시선